ChatGPT

AYSTEK CORE İçin Kurumsal Düzeyde Esnek Üçüncü Parti Entegrasyon Platformu Tasarımı

Yönetici Özeti

AYSTEK CORE'un tenant ve site bazında değişebilen (ERP/CRM/GPS/finans vb.) üçüncü parti web servislerle **sabit kod yazmadan** entegre olma ihtiyacı, klasik "her müşteri için özel entegrasyon" yaklaşımıyla sürdürülemez hale gelir. Kurumsal ölçekte doğru çözüm; **tenant+site scope'lu Connector + Action + Mapping + Hook/Trigger** modeline dayanan, güvenlik/izlenebilirlik/güvenilirlik/ölçeklenebilirlik özellikleri yerleşik bir **Integration Platform** katmanı oluşturmaktır. Bu yaklaşım iPaaS ürünlerinin (MuleSoft, Boomi, Workato, Zapier) "bağlantı/aksiyon/dönüşüm/izleme/yönetişim" kavramlarıyla örtüşür; ancak AYSTEK CORE içinde "çekirdek iş süreçlerine takılabilen", yönetim panelinden yönetilebilen ve tenant izolasyonunu koruyan bir çalışma zamanıyla uygulanır. [1]

Bu rapor, AYSTEK CORE'un mevcut teknoloji yığını ve mimari standartlarıyla uyumlu bir tasarım önerir (Go + Gin, MongoDB, Redis, RabbitMQ, OpenTelemetry/Prometheus, Next.js Admin panel gibi) ve yeni modül/menü/seed/i18n gibi kurallara uyumun kritik olduğunu varsayar.

Önerilen mimaride: - **Connector modeli**; auth türlerini (API key, Basic, OAuth2 refresh, mTLS), environment ayrımını, dışa çağrı allowlist'ini (SSRF savunması), timeouts ve rate limit/pacing politikalarını kapsar. MuleSoft HTTP connector dokümantasyonu benzer şekilde HTTP isteklerinde kimlik bilgileri ve TLS yapılandırmasını vurgular; OAuth token enforcement gibi politikalar API yönetimi seviyesinde ele alınır. [2]
- **Action modeli**; bir connector altında tanımlı endpoint/method/request/response şablonlarını, pagination ve retry sınırlamalarını, ayrıca "capability" (katalog) ile bağ kurmayı içerir. Zapier'in "triggers/searches/creates" operasyon şemaları, Workato'nun recipes/connector yaklaşımı bu soyutlamanın endüstri karşılıklarını gösterir. [3]
- **Mapping katmanı** için seçenekler JSONata (dönüşüm dili), JMESPath (JSON query dili), Handlebars/Mustache (template) veya özel DSL'lerdir. JSONata "query + transformation language" olarak güçlüdür; JMESPath "JSON için query dili" olarak daha sınırlı ama güvenli/öngörülebilir; Mustache ise "logic-less template" olarak en az sürprizli yaklaşımdır. [4]
- **Güvenlik**; SSRF için allowlist/redirect kapatma/DNS rebinding farkındalığı, secret'ların şifreli saklanması, OAuth2 token yenileme/rotasyon, mTLS (OAuth mTLS client auth ve certificate-bound tokens) ve kapsamlı audit logging ile sağlanır. [5]
- **Observability**; W3C Trace Context (traceparent/tracestate) + OpenTelemetry context propagation ile "correlation id" uçtan uca, ayrıca execution log/metrics/tracing beraber standartlaştırılır. [6]
- **Reliability**; pre/post hook, sync/async ayrımı, retry/backoff, DLQ ve idempotency/circuit breaker desenleri ile kurumsal dayanıklılık hedeflenir. RabbitMQ DLX ve TTL dokümanları DLQ/ertelemeli retry gibi mekaniklerin temelini açıklar; Azure Architecture Center retry/circuit breaker desenlerini sistematikleştirir; Apache Camel EIP'leri idempotent consumer ve dead letter channel kavramlarını referanslar. [7]
- **Data management**; incremental pull senaryolarında cursor/state yönetimi ve dedup zorunludur (Airbyte sync modes ve cursor-state kavramı). Büyük hacimli GPS verisi için MongoDB time series koleksiyonları, TTL ile retentions ve rollup stratejileri önerilir. [8]
- **Yönetişim ve DevOps**; versioning, approvals, canary release/feature flags ve tenant başına rate limit/metering ile "enterprise operational control plane" oluşturulur. Martin Fowler feature toggles ve canary

cohort yaklaşımını; Argo Rollouts canary stratejisini; AWS tenant isolation stratejileri ise veri izolasyonu çerçevesini sağlar. [9]

Aşağıdaki bölümlerde, AYSTEK CORE içinde uygulanabilir olacak şekilde; veri şemaları, API uçları, admin UI akışları, DSL v1 spesifikasyonu, güvenlik kontrol listeleri, runbook maddeleri, fazlı yol haritası ve risk azaltım planı detaylandırılmıştır.

Bağlam, Kurumsal İhtiyaç Analizi ve Tasarım İlkeleri

AYSTEK CORE bağlamında entegrasyon platformu tasarlarken iki "çerçeve koşul" belirleyicidir:
Birincisi şirketin mevcut yığını ve operasyonel standartlarıdır (Go/Gin backend, MongoDB, Redis, RabbitMQ, OpenTelemetry/Prometheus, Next.js admin; ayrıca modül yapısı, seed ve çoklu dil/i18n ve menü girişleri gibi zorunluluklar).
İkincisi, entegrasyonların tenant+site bazında farklılaşmasıdır: aynı "iş ihtiyacı" (ör. borç sorgu, konum çekme, varlık bildirme) farklı tedarikçilerin API'leriyle farklı auth ve farklı payload/parametre dönüşümleri gerektirir. Bu nedenle tasarımın çekirdeğinde "**konfigürasyonla yönetilen**" bir model olmalıdır.

Kurumsal düzeyde "esnek entegrasyon" problemini çözmek için şu tasarım ilkeleri önerilir:

Tenant ve site scope'u birinci sınıf kavramdır. Bütün connector/action/hook/mapping objeleri; "(tenant_id, site_id, environment)" bağlamında çalışmalı, aynı tenant içinde site bazında override desteklemelidir. Multi-tenant mimarilerde temel gereksinim "tenant verisinin yalnızca ilgili tenant tarafından erişilebilir olması"dır; AWS'in tenant isolation rehberleri bunu açık bir güvenlik hedefi olarak tanımlar. [10]

Konfigürasyon ile runtime ayrımı net olmalıdır. iPaaS ürünleri bu ayrımı "Exchange/Asset katalog" veya "deployment + versioning" üzerinden uygular. Örneğin Boomi, deployment sürecinin "çalışan sürümü", build tarafındaki değişikliklerden izole ettiğini; sürümleme/deployment için audit geçmişi sunduğunu belirtir. Bu, CORE içinde de "config version" ve "active version" ayrımının temel gerekçesidir. [11]

Esneklik, sınırsız bir scripting alanı değildir. Özellikle mapping DSL tarafında "her şeyi çalıştırabilen genel amaçlı kod" (JS/Python) vermek, kurumsal güvenlik ve işletim açısından yüksek risk taşır (RCE, veri sızıntısı, CPU abuse). Bunun yerine; JSONata/JMESPath gibi deklaratif diller + limitli fonksiyon seti + sandbox yaklaşımı tercih edilir. JSONata'nın "JSON için query ve transformation dili" olarak konumlanması bu çerçevede önemlidir. [12]

Enterprise-grade platformda görünürlük ve yönetişim, özellik değil zorunluluktur. Workato'nun "RecipeOps" connector'ıyla tarif ettiği şekilde; durdurulan recipe'lere ve failed job'lara otomatik aksiyon/notification üretmek ve hesap/recipe/job detaylarını çekebilmek bir "operasyonel kontrol düzlemi" ihtiyacına işaret eder. [13]

Bu ilkeler, aşağıdaki mimari önerinin tasarım kararlarını belirler.

Önerilen Kurumsal Mimari

Aşağıdaki mimari, AYSTEK CORE içinde bir "Integration Platform" modülü (config plane) ve bir "Integration Runtime" (execution plane) olarak ikiye ayrılır. Bu, MuleSoft Exchange gibi bir "asset

discovery/test/mocking" deneyimi ile, Boomi'daki deployment/versioning ve Workato'daki job monitoring yaklaşımının AYSTEK içindeki karşılığıdır. [14]

Tenant ve site scope'lu mimari diyagram

Aşağıdaki diyagram; admin UI üzerinden konfigürasyon, runtime execution, async queue, observability ve üçüncü parti servislerle veri akışını gösterir. OpenTelemetry context propagation ve W3C trace context başlıklarının yayılımı, dağıtık korelasyonun temelidir. [15]

```
flowchart LR
  subgraph Admin[Next.js Admin (AYSTEK CORE Next)]
    A1[Connector Builder\n(Postman-like)]
    A2[Mapping Editor\n(Preview + Simulator)]
    A3[Hooks/Triggers UI\n(pre/post, sync/async)]
    A4[Executions UI\nLogs/Traces/Metrics]
  end

  subgraph Core[AYSTEK CORE API (Go/Gin)]
    B1[Integrations Module\nConfig Plane]
    B2[Hook Engine\nExecution Plane]
    B3[Scheduler\n(CRON/interval)]
    B4[Outbox Publisher]
    B5[Integration Worker Pool]
    B6[Observability\n(OTel spans/metrics/logs)]
  end

  subgraph Data[Data Stores]
    D1[(MongoDB\nconnectors/actions/hooks)]
    D2[(MongoDB\nexecutions + sync_state)]
    D3[(Secrets Store\nKMS/Vault or Encrypted Fields)]
    D4[(MongoDB Time Series\nGPS positions)]
    D5[(Redis\nrate limit/caches)]
    Q[(RabbitMQ\nqueues + DLQ)]
  end

  subgraph Ext[Third-Party Systems]
    X1[ERP/CRM/Finance APIs]
    X2[GPS Provider APIs]
    X3[Partner Webhooks]
  end

  Admin -->|CRUD + Test-run| B1
  B1 --> D1
  B1 --> D3

  Core -->|Domain events| B2
  B2 -->|sync call| X1
  B2 -->|sync call| X2

  B2 -->|write execution log| D2
```

```
B2 --> B6

B3 -->|scheduled trigger| Q
B4 -->|publish async jobs| Q
Q -->|consume| B5
B5 -->|HTTP calls| X1
B5 -->|HTTP calls| X2
B5 --> D2
B5 --> D4
B5 --> B6

B2 <--> D5
B5 <--> D5

X3 -->|optional inbound webhook| Core
```

Multi-tenant/site scoping modeli

Kurumsal çoklu tenant sistemlerinde izolasyon "mantıksal" değil, **güvenceye alınmış** olmalıdır (policy + DB erişim kontrolü + audit). AWS'in tenant isolation stratejileri, izolasyonun "risk ve maliyet gereksinimine göre farklı modeller" ile tasarlanması gerektiğini vurgular. [16]

AYSTEK CORE için pratik scoping modeli: - Her config objesi (connector/action/hook/mapping) **tenant_id + site_id** taşır. - `site_id = "*" (wildcard)` bir tenant default'udur; belirli site override'ı varsa öncelik alır. - Ortam (env) ayrımı: `dev/stage/prod` veya `test/prod`. Boomi'nin "environment extensions" yaklaşımı, aynı süreç için environment bazlı değerleri (URL/credential) değiştirmeyi "hardcode" yerine yönetilebilir hale getirir; bu konsept, connector seviyesinde önerilir. [17]

Connector modeli

Connector, üçüncü partiye bağlanmanın "bağlamını" taşır; Action'lar ise connector'ın üzerinde tanımlanır.

Kurumsal connector alanları: - **Authentication türleri** - API key / header veya query param - Basic - OAuth2 (authorization code / client credentials / refresh token) - mTLS (karşı sistemin istemci sertifikası ile doğrulaması) - **TLS/mTLS gereksinimleri**: OAuth token endpoint'e yapılan isteklerde TLS zorunluluğu OAuth2 çekirdek spesifikasyonda açıkça belirtilir; mTLS tabanlı OAuth istemci doğrulaması ve certificate-bound token kavramı RFC 8705 ile tanımlanır. [18]
- **Environment ayrımı** (test/prod base URL'ler; credential setleri) - **Outbound allowlist** (domain/IP/port + DNS rebinding dikkati) - OWASP SSRF cheat sheet, allowlist yaklaşımını ve savunma odağını vurgular; OWASP Top 10 SSRF sayfası denylist/regex ile SSRF azaltımını önermediğini açıkça söyler. [19]
- **Rate limit + pacing** - Tenant/Site başına limit + connector başına limit - "429/RateLimit header" okuma ve backoff - Workato'nun webhook gateway limits dokümanı, platform seviyesinde rate limit kavramını açıkça "workspace level" limitler olarak ele alır; bu yaklaşım tenant başına rate limit tasarımına referans olabilir. [20]
- **Timeouts** - Connect timeout, read timeout, overall request budget - Workato connector limits dokümanında örnek olarak read request timeout limitinin ne olduğu açıklanır; CORE içindeki connector limits için benzer bir yapı gereklidir. [21]

MuleSoft HTTP connector dokümanı, HTTP request authentication'ın authorization header üzerinden yapılandırıldığını ve OAuth credential'larının TLS ile şifrelenebileceğini belirtir; bu "connector-level security defaults" tasarımına iyi bir endüstri referansıdır. [22]

Action modeli

Action, "bir çağrı tanımı"dır: method, URL path template, query/header/body mapping, pagination, response mapping, error handling profile.

Zapier platformu, entegrasyon operasyonlarını "triggers, searches, creates" gibi şemalarla tanımlar ve resources üzerinden otomatik operasyon üretimi sunar; bu model, AYSTEK'te "capability → action seti" ilişkisini tasarlamak için yararlı bir referanstır. [23]

Önerilen AYSTEK Action bileşenleri: - Request: - method, path, query, headers, body template - "content-type" (JSON, form-url-encoded, multipart) - Response: - success criteria (status code aralığı + optional JSON predicate) - mapping (remote → CORE canonical) - Pagination/Incremental: - page/offset/ nextToken - cursor param injection (özellikle GPS veya "tarih aralığı çekme" senaryoları için) - Error policy: - retryable status seti (429/503 vb.) - backoff/jitter parametreleri (async worker'da) - Safety: - maximum response size - redirect disabled (SSRF mitigasyonu; OWASP SSRF önerileri içinde redirect riskleri özel olarak anılır) [24]

Hook/Trigger modeli ve sync/async sınıflandırma

Kurumsal pratikte iki akış kategorisi vardır: - **Pre-hook (sync, blocking)**: İşlemin devam edip etmeyeceğini etkiler; kısa timeout; sınırlı retry; circuit breaker zorunludur. Circuit breaker deseni, "muhtemelen başarısız olacak bir operasyonu tekrar tekrar çağırıp kaynak tüketmeyi engellemek" için tanımlanır. [25]
- **Post-hook (async, non-blocking)**: Bildirim/senkronizasyon gibi yan etkiler; retry/backoff + DLQ + idempotency ile güvenilirlik sağlanır. DLQ yaklaşımı hem RabbitMQ DLX mekanikleriyle hem de Apache Camel'in Dead Letter Channel kavramıyla endüstride yerleşiktir. [26]

Async tarafta "dual-write" riskini azaltmak için Transactional Outbox deseni önerilir: iş verisi güncellemesi ile event üretimi aynı transaction içinde DB'ye yazılır; ayrı publisher outbox'tan kuyruğa basar. Microservices.io, outbox desenini "aggregate update + event publish" ihtiyacının atomik yapılması gereğiyle açıklar. [27]

Dönüşüm Katmanı ve Mapping DSL Seçimi

Entegrasyon platformunun "en zor" parçası, farklı API şemaları arasında dönüşüm yapmaktır. Burada iki farklı yaklaşım vardır:

Template yaklaşımı: JSON şablonuna alan enjekte edilir (Mustache/Handlebars gibi). Mustache "logic-less"tir; yani template içinde if/loop gibi uygulama logic'i gömmez; bu, güvenlik ve anlaşılabilirlik açısından artıdır. [28]
Expression yaklaşımı: JSON üzerinde seçme/filtreleme/dönüştürme yapan deklaratif ifadeler kullanılır (JMESPath/JSONata). JMESPath JSON query dili olup extraction/transform yapmayı hedefler; JSONata ise JSON için daha güçlü bir query+transformation dilidir. [29]

Kurumsal gerçeklikte pratik olan, **hibrit** yaklaşımdır:
- "Basit alan map'leri" template ile

- “Kapsamlı reshape/aggregate/conditional logic” expression ile
Bu hibrit, Boomi/Workato gibi platformların “mapping + küçük dönüşümler” yaklaşımına benzer; fakat AYSTEK içinde daha kontrollü bir DSL ile uygulanır. [30]

Mapping DSL seçenekleri ve tradeoff analizi

Aşağıdaki tablo, enterprise kriterleriyle (security, expressiveness, performans, öğrenme eğrisi) DSL seçeneklerini karşılaştırır. (Kaynak özellik tanımları ilgili resmi dokümanlar ve Go ekosistemi referanslarından derlenmiştir.) [31]

Seçenek	Temel amaç	İfade gücü	Güvenlik profili	Go ekosistemi/ performans	Öğrenme eğrisi	Enterprise kullanım yorumu
JSONata	JSON query + transformation	Çok yüksek (fonksiyonel dönüşüm) [12]	Güçlü ama “sandbox/ limit” şart; ağır ifadeler DoS olabilir	Go portları var; sürüm uyumu/ feature parity yönetilmeli [32]	Orta-yüksek	Karmaşık şema dönüşümleri için ideal; governance + expression budget zorunlu
JMESPath	JSON query dili	Orta (seç/ filtrele/ reshape) [33]	Görece güvenli, deterministik; fonksiyon seti sınırlı	Go implementasyonu yaygın/olgun [34]	Orta	“Extraction + hafif transform” için iyi; en az sürprizli yaklaşım
Handlebars	Template + helper	Orta (helper ile yükselir) [35]	Helper’lar büyürse “gömülü logic” artar; escaping kuralları önemli	Go portu mevcut ancak bazı projeler archived olabilir [36]	Düşük-orta	UI/JSON templating için pratik; kurumsalda helper setini sınırlamak gerekir
Mustache	Logic-less template	Düşük [37]	Güvenli/ öngörülebilir (logic yok)	Go implementasyonu yaygın [38]	Düşük	Basit map işleri için mükemmel; karmaşık dönüşümler için yetersiz kalır

Seçenek	Temel amaç	İfade gücü	Güvenlik profili	Go ekosistemi/ performans	Öğrenme eğrisi	Enterprise kullanım yorumu
Özel DSL	İhtiyaca özel	Sizin seçiminiz	En riskli: tasarım/bug/ escape/ sandbox yükü	Performans kontrolü sizde; bakım maliyeti yüksek	Değişken	Sadece “v1 minimal” için küçük expression seti olarak anlamlı; genel amaçlı dil yazmaktan kaçının

Öneri: AYSTEK Mapping DSL v1 yaklaşımı

AYSTEK CORE için **en dengeli** öneri: - **JMESPath (expression)** + **JSON Template (Mustache benzeri)** hibriti - Ayrıca “kısıtlı yardımcı fonksiyonlar” (date/number/string, hash/hmac, uuid)
Gerekçe: - JMESPath’in resmi/olgun tanımı ve Go ekosistemi güçlüdür. [39]
- Mustache “logic-less” olduğu için template tarafında kontrolsüz logic büyümesini engeller. [37]
- JSONata çok güçlüdür; ancak expression budget/sandbox olmadan “enterprise güvenlik” açısından risklidir; JSONata’yı v2+ aşamasında “advanced mode” olarak eklemek daha güvenli bir stratejidir. [40]

Mapping DSL v1 spesifikasyonu

Aşağıdaki spec, yönetilebilirlik ve güvenlik arasında denge kurmayı hedefler.

Temel kavramlar - `input`: CORE event/command payload + context (tenant/site/user/request_id) - `vars`: kullanıcı tanımlı “computed values” - `request`: method/path/query/headers/body template - `response`: output mapping + error mapping

Expression dili - Default: **JMESPath** - Expression evaluation: - Maksimum süre (ör. 10–50ms) ve maksimum çıktı boyutu - Maksimum node/AST derinliği (DoS engeli) - Fonksiyon seti (v1): - `now()` → RFC3339 - `to_string(x)`, `to_number(x)`, `to_bool(x)` - `default(x, y)` (x null/empty ise y) - `concat(a,b,...)` - `lower(x)`, `upper(x)`, `trim(x)` - `parse_time(x, layout)`, `format_time(t, layout)` - `uuid_v4()` - `sha256(x)`, `hmac_sha256(secret, payload)` (webhook imzası vb.) - `base64(x)` - Güvenlik notu: `hmac_sha256` gibi fonksiyonlar secret erişimi gerektirir; bu secret “mapping’de düz metin” değil, secrets store referansı üzerinden çözülmelidir.

Template dili - JSON template, Mustache benzeri: - `{{ jmespath_expr }}` yalnızca “value injection” yapar - Template içinde kontrol yapıları yok (logic-less) - İsteğe bağlı: “missing field policy” - strict: eksik alan → validation error - lenient: eksik alan → null/omit

Validation - Connector/action test-run sırasında: - request preview - response preview - schema check (optional) - “dry run” modu ile gerçek çağrı yapmadan mapping doğrulama (simulator)

Bu spec; iPaaS ürünlerinin “UI üzerinden mapping preview/test-run” yaklaşımını AYSTEK içinde tekrarlar. (MuleSoft Exchange’in test/simülasyon ve mocking servisleri gibi deneyimler bu gereksinimi doğrular.) [41]

Güvenlik, Uyumluluk ve Yönetişim

Enterprise entegrasyon platformu; “dış dünyaya HTTP çağrısı yapan bir runtime” olduğu için, güvenlikte küçük bir hata tüm tenant verilerini riske atabilir. Bu bölüm; SSRF/secret/OAuth/mTLS/audit/encryption/ tenant isolation ve governance başlıklarını kapsar.

SSRF ve outbound kontrollü erişim

OWASP SSRF cheat sheet, SSRF savunmasını özellikle “defensive” bakışla ele alır; OWASP Top 10 SSRF dokümanı denylist/regex’i SSRF mitigasyonu olarak önermediğini açıkça belirtir. [19]

AYSTEK CORE için minimum SSRF kontrol seti: - **Positive allowlist**: host + port + scheme (`https` default) - **DNS rebinding önlemleri**: resolve sonrası IP’nin private range olup olmadığını kontrol; TTL caching kısa; “time-of-check/time-of-use” farkındalığı (OWASP SSRF sayfası DNS rebinding ve TOCTOU risklerinden bahseder). [24]
- **Redirect kapalı**: 30x redirect’leri takip etme - **IP range blokları**: localhost, link-local, RFC1918, metadata endpoints (169.254.169.254) - **Response size limit** ve **content-type allowlist**: veri sızıntısı ve memory abuse engeli - **Egress network policy**: mümkünse network seviyesinde de allowlist

Secret storage, encryption at rest/in transit

Kurumsal pratikte secret yönetimi iki katmanlı olmalıdır: - **At rest encryption**: DB seviyesinde veya uygulama seviyesinde “alan bazlı encryption” - **External secrets manager** opsiyonu: Vault/KMS gibi sistemler ile rotasyon

MongoDB Client-Side Field Level Encryption (CSFLE), verinin uygulama tarafından şifrelenip MongoDB’ye öyle gönderilmesini ve MongoDB ürünlerinin şifrelenmemiş veriye erişememesini hedefler; bu, connector secrets için güçlü bir yaklaşım sunar. [42]
n8n’in “custom encryption key” dokümanı, credential’ların DB’ye yazılmadan önce encryption key ile şifrelendiğini ve queue mode’da worker’ların aynı encryption key’i paylaşması gerektiğini belirtir; benzer operational gereksinimler AYSTEK worker mimarisi için de geçerlidir. [43]

Secret rotasyonu için HashiCorp Vault tarafında “auto-rotating secrets” ve “dynamic secrets” ayrımı ve rotasyonun risk azaltıcı rolü anlatılır. [44]

OAuth2 refresh, token revocation, token rotation

OAuth2 çekirdek RFC 6749, refresh token ile access token yenilemeyi tanımlar; token endpoint’e yapılan çağrılarda TLS zorunluluğunu da vurgular. [45]
Token iptali (logout/compromise) için RFC 7009 “token revocation endpoint” tanımlar. [46]
OAuth güvenlik en iyi pratikleri; IETF’nin “Best Current Practice for OAuth 2.0 Security” (RFC 9700) belgesiyle güncellenmiştir; bu belge, OAuth2’nin geniş kullanımına bağlı yeni tehditleri ve bazı güvensiz modların terk edilmesini kapsar. [47]
OWASP OAuth2 cheat sheet de OAuth2 için güncel güvenlik önerilerini RFC’lerden türeterek özetler. [48]

Workato connector SDK dokümanları; OAuth2 auth-code grant için token url/client id/secret kavramlarını ve oauth2 bağlantılarda “refresh” ile yeniden yetkilendirme mekanizmasının tetiklendiğini açıklar; bu, AYSTEK connector runtime’da refresh token yönetimi için pratik bir referanstır. [49]
Zapier dokümanı da refresh token fonksiyonu etkin olduğunda OAuth v2 ve session kimlik doğrulamalarının otomatik yenilenebildiğini belirtir. [50]

mTLS (Mutual TLS)

OAuth için mTLS tabanlı istemci doğrulama ve certificate-bound access/refresh token kavramı RFC 8705 ile tanımlanır. [51]
Kurumsal bağlamda mTLS iki yerde gerekir: - CORE → third-party outbound çağrılarda “client cert” - inbound webhook uçlarında partner doğrulama (opsiyonel)

Audit logging ve compliance

OWASP Logging Cheat Sheet, güvenlik odaklı uygulama loglamasının önemine (yalnız altyapı loglarına güvenmemek) vurgu yapar. [52]
AYSTEK Integration Platform’ta audit kapsamı: - Connector/action/hook değişiklikleri (kim, ne zaman, neyi değiştirdi) - Secret erişimi (maskeli; sadece “okundu/yenilendi” gibi olaylar) - Test-run çalıştırmaları (hangi kullanıcı, hangi payload ile) - Execution sonuçları ve retry/DLQ hareketleri

Compliance tarafında minimum: - In transit: TLS everywhere (OAuth token endpoint TLS şartı, RFC 6749) [53]
- At rest: secrets encryption (CSFLE veya Vault KMS) [54]
- Tenant isolation ve erişim kontrolü (AWS tenant isolation stratejileri çerçevesi) [16]

Governance: catalog/capabilities, versioning, approvals, change management

iPaaS dünyasında “asset catalog + reusable patterns” yaklaşımı yaygındır. MuleSoft Exchange; asset’leri keşfetme/paylaşma/test/simülasyon/mocking gibi kabiliyetlerden söz eder. [55]
Workato custom connector docs, connector’ların private scope olabildiğini; “global scope” için review gerektiğini belirtir. Bu, enterprise governance açısından “onay kapısı” gibi düşünülebilir. [56]
Boomi deployment dokümanı; süreçlerin çalışan sürümünü build değişikliklerinden izole etmek, sürümleme ve deployment için audit geçmişi sunmak gibi governance hedeflerini açıklar. [11]

AYSTEK için öneri: - “Capability Catalog”: `gps.latest_position`, `customer.debt_lookup`, `vehicle.context_lookup`, `asset.push` gibi isimlendirilmiş yetenekler - Her capability: - beklenen input (CORE canonical) - beklenen output (CORE canonical) - required action seti (örn. GPS için `getLatestPositions`, `getPositionsRange`) - Approval flow: - draft → review → active - prod’a çıkış sadece onayla - Versioning: - config objelerinde `version`, `active_version`, `rollback_to` - Testing: - test-run kaydı “replayable” (aynı input ile) - smoke test checklist enforced

Observability, Güvenilirlik, Ölçeklenebilirlik ve Veri Yönetimi

Bu bölüm, runtime’ın “enterprise SLO” seviyesinde çalışması için gerekli mekanikleri toplar.

Observability: execution logs, tracing, metrics, correlation IDs

Trace context standardı: W3C Trace Context, `traceparent` ve `tracestate` başlıklarıyla dağıtık iz sürmeyi standardize eder. [57]
OpenTelemetry context propagation: sinyallerin (trace/metrics/logs) korelasyonu için context propagation kavramını tanımlar. [58]
HTTP semantic conventions: HTTP client/server span ve metrikleri için oturmuş attribute setini sağlar. [59]

AYSTEK runtime'da önerilen telemetry: - Her integration execution için: - Span: `integration.execute` - Attributes: `tenant_id`, `site_id`, `connector_id`, `action_key`, `hook_key`, `phase`, `mode`, `http.method`, `http.url` (maskeli), `http.status_code`, `retry_count`, `duration_ms` - Metrics: - `integration_requests_total{tenant,site,connector,action,status}` - `integration_duration_ms_bucket{...}` - `integration_failures_total{reason}` - `integration_queue_lag` (async backlog) - Logs: - OWASP logging önerilerine uygun şekilde "security relevant events" ayrı sınıflandırma [52]
- PII/secret maskeleme zorunlu

Güvenilirlik: sync vs async, retries, backoff, DLQ, idempotency, circuit breaker

Circuit Breaker: Microsoft'un Circuit Breaker pattern dokümanı, başarısız olması beklenen operasyonların tekrar tekrar denenmesinin kaynak tüketimini artıracağını ve devre kesicinin bunu önlediğini açıklar. [60]
Retry: Retry pattern dokümanı, uzun sürecek hatalarda circuit breaker ile birlikte kullanılabileceğini vurgular. [61]

DLQ: - RabbitMQ Dead Letter Exchanges (DLX) bir queue için dead letter exchange tanımlama mekanizmasını açıklar. [62]
- RabbitMQ TTL dokümanı, per-message TTL (`expiration`) ve TTL dolunca dead-letter edilebilme davranışını anlatır; bu, "delayed retry queue" tasarımı için kritik bir building block'tur. [63]
- Apache Camel Dead Letter Channel, hata alan mesajların "dead letter queue"ya taşınması prensibini EIP olarak tanımlar; mimari desenin kavramsal temelini güçlendirir. [64]

Idempotency/dedup: - Apache Camel Idempotent Consumer EIP, duplicate mesajları filtrelemek için tasarlanmıştır ve Camel'in message id'yi "duplication detection" için repository'ye eklediğini belirtir. [65]

AYSTEK Integration Worker için önerilen pratik: - Async mesajı tüketirken: - `idempotency_key = hash(tenant_id, site_id, hook_id, event_id, action_id, attempt)` (deneyime göre) - `executions` koleksiyonunda unique index veya ayrı `idempotency` koleksiyonu - duplicate görüldüğünde "skip + log" (idempotent consumer mantığı) [65]
- Retry stratejisi: - 429/503/timeouts → exponential backoff + jitter - Validation hatası (4xx) → retry yok, direkt DLQ - DLQ yönetimi: - "DLQ triage UI" + manuel/otomatik redrive süreçleri

Ölçeklenebilirlik: kuyruklama, workers, partitioning ve throughput hedefleri

AYSTEK CORE ekosisteminde kuyruk/worker yaklaşımı zaten mevcut teknoloji yığınına uyumludur (RabbitMQ + worker, Redis, observability).

Worker ölçekleme: - n8n'in queue mode dokümanı; ana instance'ın execution ürettiğini, worker'ların execution'ları çalıştırdığını ve worker ekleyip çıkararak yatay ölçeklenebildiğini anlatır. [66]
Bu model, AYSTEK Integration Worker Pool için de doğrudan uygulanabilir: "control plane" (admin/API) ayrı, "execution plane" (workers) ayrı ölçeklenir.

Kafka alternatif/opsiyonel: - Kafka'da partition sayısı, consumer group içinde paralelliği belirler; Confluent dokümanı "partition başına bir consumer instance" kuralını ve daha çok partition'ın throughput'u artırabileceğini belirtir. [67]
AYSTEK'in mevcut RabbitMQ kullanımında Kafka zorunlu değildir; ancak "çok yüksek throughput +

ordering key” gerektiren senaryolarda (örn. GPS telemetry milyonlarca event/gün) Kafka opsiyon olarak mimariye dahil edilebilir.

Throughput hedefleme (öneri, tasarım parametresi)
Kesin sayı vermek yerine “hedefleme yaklaşımı” önerilir: - Her tenant için: - `max_rps_outbound` (connector config) - `max_concurrency` (worker pool) - Her action için: - `p95_latency_budget` - `timeout_ms` (sync)
Bu hedefler; vendor rate limit’leri ve internal SLO’lara göre “tenant başına config” olarak yönetilir (Workato’nun platform limitleri ve webhook gateway limits yaklaşımı buna benzer bir platform düzeyi limit mantığı gösterir). [68]

Veri yönetimi: cursor/last_sync, dedup, büyük GPS verisi, retention/rollups

Incremental sync state/cursor: - Airbyte incremental sync dokümanı, incremental sync için cursor field, datetime formatları ve request injection gibi konfigürasyonların gerektiğini; cursor’ın “hangi kayıtların senkronize edildiğini” belirlemek için kullanıldığını açıklar. [69]
- Airbyte “Incremental - append + deduped” sayfası cursor ve cursor field kavramlarını net tanımlar; bu, AYSTEK `sync_state` modelinin terminolojisini güçlendirir. [70]

GPS gibi büyük veri için MongoDB time series + TTL: - MongoDB TTL indeksleri, belirli süre/saate göre otomatik veri silmeye izin verir. [71]
- MongoDB time series “best practices” dokümanı; compression, sharding, insert ve query performansı için öneriler sunar. [72]
Bu iki özellik birleşince: - `vehicle_last_position` gibi “son bilinen konum” hızlı okunan koleksiyon - `gps_positions_ts` time series koleksiyonu (ham telemetri) - TTL ile ham telemetri 30/90/180 gün saklama - Rollup koleksiyonları (saatlik/günlük özet) ile raporlama maliyetini düşürme

Kurumsal veri yaşam döngüsü yönetimi için bu yaklaşım, operasyonel olarak batch cleanup ihtiyacını minimize eder (TTL’nin otomatik silme davranışı). [71]

Uygulama Taslağı: Karşılaştırmalar, Şema, API, UI, Runbook, Yol Haritası ve Riskler

Bu bölüm, istenen somut çıktıları (tablolar, şema, API uçları, UI sayfaları, runbook, roadmap, riskler) tek yerde toplar.

Mapping DSL ve connector runtime karşılaştırma tablosu

Aşağıdaki tablo, “in-house (AYSTEK Integration Platform)” ile endüstri ürünlerini ve OSS projeleri, enterprise boyutlarda karşılaştırır. (Cümleler ilgili resmi dokümanlardaki özellik tanımlarına dayanır.) [73]

Runtime/ Platform	Konumlandırma	Governance & Versioning	Connector/ Asset ekosistemi	Güvenlik & Secret yaklaşımı	Ölçekleme modeli	AYSTEK için çıkarım
AYSTEK Integration Platform (önerilen)	CORE içi, tenant/site native	Config version + approvals + audit (tasarlanacak)	“Capability catalog” + HTTP/OpenAPI tabanlı action’lar	OWASP SSRF + Vault/CSFLE + OAuth2/mTLS (tasarlanacak)	RabbitMQ worker pool + opsiyonel Kafka	CORE workflow’larına en iyi entegre olur; en yüksek kontrol
MuleSoft Anypoint (Exchange + API Manager)	iPaaS + API yönetimi	Exchange asset yönetimi, test/ simülasyon/ mocking [41]	Reusable assets/ connectors/ templates [74]	OAuth token enforcement policy örneği [75]	Platform tarafından yönetilir	Referans mimari/UX fikri verir; CORE içinde subset’i uygulanabilir
Boomi	iPaaS	Deployment sürüm izolasyonu + audit history [11]	Connector bileşenleri + environment extensions [76]	Platform yönetimli	Runtime atom/ molecule ile ölçeklenir	AYSTEK’te “environment override + versioned deploy” tasarımına iyi örnek
Workato	Enterprise automation iPaaS	RecipeOps ile job/recipe izleme [13]	Connector SDK + OAuth2 entegrasyon pratikleri [49]	Platform limitleri + gateway rate limit [68]	Platform managed	“Ops control plane + otomatik iyileştirme” fikri AYSTEK runbook/UI’ına taşınmalı
Zapier	iPaaS (daha self-serve)	Operasyon şemaları (triggers/ searches/ creates) [77]	Integration schema yaklaşımı	OAuth v2 refresh otomasyonu notu [50]	Platform managed	“Operation schema” yaklaşımı capability/ action modeline ilham verir
Apache Camel	OSS integration framework	EIP’ler (dead letter, idempotent consumer) [78]	Yüzlerce component [79]	Uygulama sorumluluğunda	JVM tabanlı	Doğrudan ürün değil; desen ve “integration patterns” için birincil referans

Runtime/ Platform	Konumlandırma	Governance & Versioning	Connector/ Asset ekosistemi	Güvenlik & Secret yaklaşımı	Ölçekleme modeli	AYSTEK için çıkarım
Airbyte	OSS data integration	State/cursor + incremental sync kavramları [80]	Connector builder (auth/ pagination) [81]	Credential'ı güvenli saklama yaklaşımı [82]	Connector runner ölçeklenir	GPS/ERP "pull" senaryolarında cursor/state tasarımına doğrudan referans
n8n	OSS workflow automation	Konfig + execution ayrımı (queue mode) [83]	Node tabanlı entegrasyonlar	Credential encryption key [43]	Worker + Redis queue [84]	Worker ölçekleme ve credential encryption operasyonel gereksinimleri için iyi referans

MongoDB şema önerisi ve indeksler

Aşağıdaki koleksiyonlar, istenen "connectors/actions/hooks/executions/sync_state/secrets" ayrımını kurar. Mongo TTL ve time series pratikleri özellikle executions ve GPS için kritiktir. [85]

`connectors` **koleksiyonu**

Örnek alanlar: - `_id` - `tenant_id`, `site_id` - `key` (örn. `gps_provider_main`) - `name` - `env` (`test|prod`) - `base_url` - `auth`: - `type` (`api_key|basic|oauth2|mtls|none`) - `oauth2`: `token_url`, `client_id_ref`, `client_secret_ref`, `scopes`, `refresh_token_ref`, `audience`, `grant_type` - `mtls`: `client_cert_ref`, `client_key_ref`, `ca_bundle_ref` - `allowlist`: `hosts[]`, `ports[]`, `schemes[]` - `timeouts`: `connect_ms`, `read_ms`, `total_ms` - `rate_limit`: `max_rps`, `max_concurrency`, `burst` - `status`: `draft|active|disabled` - `version`, `active_version` - `created_at`, `updated_at`

Önerilen indeksler: - `({tenant_id:1, site_id:1, key:1, env:1}, unique)` - `({tenant_id:1, site_id:1, status:1})`

`actions` **koleksiyonu**

Alanlar: - `_id` - `tenant_id`, `site_id` - `connector_id` - `key` (örn. `get_latest_positions`) - `http`: `method`, `path_template`, `query_template`, `headers_template`, `body_template`, `content_type` - `mapping`: - `request_vars` (computed expressions) - `response_map` (JMESPath expressions) - `success_criteria` (status, predicate) - `pagination` (opsiyonel) - `error_policy`: retryable codes, max attempts, backoff profile - `version`, `active_version` - `created_at`, `updated_at`

İndeks: - `({tenant_id:1, site_id:1, connector_id:1, key:1}, unique)`

`hooks` **koleksiyonu**

Alanlar: - `_id` - `tenant_id`, `site_id` - `key` - `trigger`: - `type` (`domain_event|operation|on_demand|scheduled|webhook_in`) - `name` (örn. `vehicle.asset_added`) - `phase` (`pre|post`) - `mode` (`sync|async`) - `action_ref`: `action_id` + `action_version` - `enabled` - `sync_timeout_ms` - `async_policy`: `queue`, `priority`, `max_attempts`, `dlq_policy` - `version`, `active_version` - `created_at`, `updated_at`

İndeks: - `({tenant_id:1, site_id:1, trigger.type:1, trigger.name:1, phase:1}, unique)` - `({tenant_id:1, site_id:1, enabled:1})`

`executions` **koleksiyonu**

Alanlar: - `_id` - `tenant_id`, `site_id` - `hook_id`, `action_id`, `connector_id` - `correlation_id` (CORE request id) + `traceparent` - `mode`, `phase` - `attempt` - `status` (`success|failed|retrying|dlq`) - `timings`: `started_at`, `finished_at`, `duration_ms` - `http`: `status_code`, `endpoint_hash`, `request_bytes`, `response_bytes` - `error`: `code`, `message_hash`, `category` (timeout/ssrf/validation/5xx/4xx) - `idempotency_key` - `payload_sample_ref` (opsiyonel; PII maskeleme ile)

İndeks: - `({tenant_id:1, site_id:1, started_at:-1})` - `({tenant_id:1, site_id:1, status:1, started_at:-1})` - `({tenant_id:1, site_id:1, idempotency_key:1}, unique)` (uygun senaryolarda)

TTL: - Execution log retention için TTL index kullanılabilir (Mongo TTL özelliği). [71]

`sync_state` **koleksiyonu**

Airbyte tarzı cursor/state tutma modeliyle uyumludur. [80]
Alanlar: - `_id` - `tenant_id`, `site_id` - `capability_key` veya `action_key` - `state`: - `cursor_field` - `cursor_value` - `last_sync_at` - `last_success_at` - `watermark` (opsiyonel) - `stats`: processed_count, duplicate_count - `updated_at`

İndeks: - `({tenant_id:1, site_id:1, capability_key:1}, unique)`

`secrets` **koleksiyonu**

Öneri: secrets'ı mümkün olduğunca DB'de "plaintext" tutmamak: - CSFLE veya Vault ref (Mongo CSFLE yaklaşımı) [42]
- `secret_ref` ile dış secrets manager

Alanlar: - `_id` - `tenant_id`, `site_id` - `key` - `type` (`api_key|client_secret|refresh_token|cert|private_key`) - `ciphertext` veya `external_ref` - `rotation`: `enabled`, `last_rotated_at`, `next_rotate_at` - `created_at`, `updated_at`

İndeks: - `({tenant_id:1, site_id:1, key:1}, unique)`

Go API uçları ve handler sorumlulukları

AYSTEK CORE backend standartları (Gin router, `/admin/*` grupları, DDD modül katmanları) doğrultusunda, Integration Platform için örnek endpoint seti aşağıdaki gibi tasarlanabilir.

Connector yönetimi - `GET /admin/integrations/connectors`
Sorumluluk: tenant/site filtreli liste, pagination - `POST /admin/integrations/connectors`
Sorumluluk: connector create (draft), allowlist/timeout/rate_limit validasyonu - `GET /admin/integrations/connectors/:id`
Sorumluluk: detail + masked secrets refs - `PUT /admin/integrations/connectors/:id`
Sorumluluk: version bump, status transition (draft→active için approval gerekebilir) - `POST /admin/integrations/connectors/:id/test`
Sorumluluk: ping/healthcheck action (optional default action)

Secrets - `POST /admin/integrations/secrets`
Sorumluluk: secret create/update (masking), encryption/external_ref çözümü - `GET /admin/integrations/secrets`
Sorumluluk: list (değer yok, sadece metadata) - `POST /admin/integrations/secrets/:id/rotate`
Sorumluluk: rotasyon tetikle (Vault auto-rotation ile entegre edilebilir) [44]

Actions - `GET /admin/integrations/actions?connector_id=`
- `POST /admin/integrations/actions`
- `GET /admin/integrations/actions/:id`
- `PUT /admin/integrations/actions/:id`
- `POST /admin/integrations/actions/:id/test-run`
Sorumluluk: request preview + gerçek çağrı + response mapping preview (Postman benzeri deneyim)

Hooks/Triggers - `GET /admin/integrations/hooks`
- `POST /admin/integrations/hooks`
- `PUT /admin/integrations/hooks/:id`
- `POST /admin/integrations/hooks/:id/enable|disable`
- `POST /admin/integrations/hooks/:id/dry-run`
Sorumluluk: sample event ile dry-run (simulator)

Executions - `GET /admin/integrations/executions`
Filtre: tenant/site/connector/action/status/time range - `GET /admin/integrations/executions/:id`
Sorumluluk: detay + trace link + retry history - `POST /admin/integrations/executions/:id/retry`
Sorumluluk: manuel retry veya DLQ redrive

Sync state - `GET /admin/integrations/sync-state`
- `PUT /admin/integrations/sync-state/:id/reset`
Sorumluluk: cursor reset (controlled)

Next.js admin sayfaları ve ana UI etkileşimleri

AYSTEK CORE admin panelinde (Next.js) önerilen sayfa seti:

- `/admin/integrations/connectors`
- Liste, durum (draft/active), tenant/site filtre
- `/admin/integrations/connectors/new`
- Wizard: base URL, auth, allowlist, timeout, rate limit, env
- `/admin/integrations/connectors/[id]`
- Detay + "Test connection"
- `/admin/integrations/actions`
- Connector seç → actions list
- `/admin/integrations/actions/new`
- Method/path/query/header/body tanımı + mapping editor
- `/admin/integrations/actions/[id]/test-run`
- Postman-like: sample input → request preview → execute → response preview
- `/admin/integrations/hooks`
- Trigger seçimi, pre/post + sync/async, enabled toggle
- `/admin/integrations/executions`
- Filtrelenebilir tablo, status drill-down
- `/admin/integrations/executions/[id]`
- Attempt timeline, DLQ reason, trace link, "retry"
- `/admin/integrations/catalog`
- Capability listesi, required actions, onboarding checklist

UI etkileşim prensipleri: - Her değişiklik "taslak → test → onay → aktif" akışı - Preview her zaman "maskelenmiş" payload gösterir - Test-run çıktısı kaydedilir ve "replay" edilebilir

Bu UX, MuleSoft Exchange'in "test/simulate/mocking" ve Workato'nun "job monitoring" yaklaşımını, AYSTEK'in modüler admin deneyimine uyarlama hedefi taşır. [86]

Güvenlik kontrol listesi

OWASP SSRF ve Logging rehberleri ile OAuth RFC'ler (TLS, revocation, BCP) temel alınarak "minimum enterprise" checklist aşağıdaki gibi uygulanmalıdır. [87]

- Outbound HTTP
- Allowlist enforced (host/scheme/port)
- Redirect disabled
- DNS rebinding kontrolleri
- Response size limit + content-type allowlist
- Secret management
- Secret maskleme (UI ve log)
- At-rest encryption (CSFLE veya external secrets) [42]
- Rotasyon planı (Vault auto-rotation gibi) [44]
- OAuth2
- Token endpoint TLS zorunlu [53]
- Refresh token / token revocation endpoint desteği [88]
- RFC 9700 önerilerine göre güvenli flow seçimi ve zayıf modlardan kaçınma [89]
- mTLS
- Sertifika/anahtar saklama policy

• Sertifika yenileme prosedürü
• Logging/Audit
• OWASP Logging guidance: security events, tamper-evident storage [52]
• PII minimizasyonu
• Tenant isolation
• DB query her zaman tenant/site filtreli
• Admin rol izinleri ve audit

Operasyonel runbook maddeleri

Workato'nun RecipeOps yaklaşımı ve boomi deployment/versioning "audit history" gibi kavramlar, operasyon runbook'unda "tanımlı aksiyonlar" olması gerektiğini gösterir. [90]

Önerilen runbook başlıkları: - DLQ triage - DLQ kuyruğuna düşen mesajların kategori bazlı sınıflandırılması (validation vs transient) - "Redrive" prosedürü - Connector health - "Test connection" başarısızlıklarında hızlı teşhis (DNS, allowlist, certificate expiry) - OAuth incident - Refresh token invalid → re-auth flow - Token compromise → RFC 7009 revocation akışı [91]
- SSRF alarmı - Allowlist ihlali veya private IP erişim teşebbüsü → incident aç - Performans/backlog - Queue lag artışı → worker scale-out (n8n queue mode ölçekleme mantığı) [83]
- Canary rollout - Feature flag ile sınırlı tenant/site'daki rollout (Fowler canary cohort) [92]
- Argo Rollouts ile canary step/pause/weight (varsa) [93]

Fazlı uygulama yol haritası

Aşağıdaki plan "MVP → v1 → enterprise" şeklinde, riskleri yöneterek ilerlemeyi amaçlar. (Zamanlar örnektir; ekip büyüklüğü ve mevcut altyapıya göre değişir.)

MVP - Connector CRUD (tenant/site/env) - Action CRUD (HTTP request tanımı) - Mapping v1: Mustache template + JMESPath expressions - Test-run UI (request preview + gerçek çağrı) - Async post-hook (RabbitMQ) + basic DLQ - Execution log (Mongo) + temel metrikler (OTel) [94]

v1 - Pre-hook sync execution (timeout + circuit breaker) [60]
- Retry/backoff profilleri + delayed retry (RabbitMQ TTL + DLX) [95]
- Idempotency key + dedup (Idempotent Consumer konsepti) [65]
- Scheduler triggers - Sync_state (cursor/last_sync) (Airbyte terminolojisiyle uyumlu) [80]
- GPS için Mongo time series + TTL retention [96]

Enterprise - Capability catalog + approval workflow + versioned deploy (Boomi benzeri) [11]
- Secrets: CSFLE veya Vault entegrasyonu + rotasyon [54]
- OAuth2 revocation + RFC 9700 sertleşmeleri [97]
- Canary + feature flags (Fowler) [92]
- Tenant bazlı metering/limit enforcement (platform limits yaklaşımı referans alınabilir) [68]
- Ops control plane: "RecipeOps benzeri" otomatik iyileştirme ve alarm entegrasyonları [13]

Migrasyon ve upgrade stratejisi

Mevcut sabit entegrasyonlar varsa, taşınma stratejisi: - "Strangler" yaklaşımı: her entegrasyon capability bazında yeni platforma taşınır; eski yol feature flag ile kapatılır. Feature toggle yaklaşımı ve canary cohort kavramı bu stratejiyi destekler. [92]
- Config versioning: - Yeni connector/action/hook "draft" olarak oluşturulur - Test-run + staging ortamında doğrulanır (Boomi environment extensions benzeri env override mantığı) [76]

- Prod’da küçük tenant/site canary → genişleme - Backward compatibility: - DSL v1 sürümü pinned - Mapping değişimlerinde “active_version” rollback

Öncelikli riskler ve azaltım planı

SSRF ve ağ içi veri sızıntısı
Risk: user-configured URL üzerinden iç ağ servislerine erişim.
Mitigasyon: OWASP SSRF önerilerine uygun allowlist + redirect kapalı + DNS rebinding kontrolleri. [19]

Secrets sızıntısı ve token ele geçirilmesi
Risk: OAuth refresh token/sertifika/private key loglara veya DB’ye düz metin düşer.
Mitigasyon: encryption at rest (CSFLE) + Vault rotasyon + maskeli UI/log; OAuth TLS zorunluluğu; revocation endpoint (RFC 7009); BCP (RFC 9700). [98]

Sync pre-hook ile çekirdek akışların yavaşlaması
Risk: üçüncü parti yavaş/çöker → CORE işlemleri bloklanır.
Mitigasyon: default async; sync sadece gerekli yerde; kısa timeout; circuit breaker. [60]

Retry fırtınası ve kuyruk şişmesi
Risk: yanlış retry policy ile backlog, maliyet ve downstream rate-limit ihlali.
Mitigasyon: TTL+DLX tabanlı gecikmeli retry; rate limit/pacing; DLQ triage. [99]

Mapping DSL DoS ve karmaşıklık patlaması
Risk: aşırı complex expression’lar CPU/mem tüketir; governance zayıfsa “konfig yazılımına” dönüşür.
Mitigasyon: expression budget (time/size/depth), “logic-less template” sınırı, capability catalog + approval. [100]

Incremental sync duplicate ve veri tutarsızlığı
Risk: cursor yanlış güncellenir veya inclusive query duplicate üretir.
Mitigasyon: Airbyte’nin cursor/state kavramlarına benzer net sync_state modeli + idempotent consumer/dedup + rollup stratejisi. [101]

Bu tasarım; AYSTEK CORE’un mevcut teknoloji ve mimari standartlarıyla uyumlu şekilde, “Postman benzeri test edilebilirlik + yönetilebilir mapping + workflow’a takılabilir hooks” hedefini enterprise seviyesinde karşılayacak bir çerçeve sunar.

---

[1] [14] [41] [55] [73] [86] https://docs.mulesoft.com/exchange/
https://docs.mulesoft.com/exchange/

[2] [22] https://docs.mulesoft.com/http-connector/latest/http-authentication
https://docs.mulesoft.com/http-connector/latest/http-authentication

[3] [23] [77] https://github.com/zapier/zapier-platform/blob/main/packages/schema/docs/build/schema.md
https://github.com/zapier/zapier-platform/blob/main/packages/schema/docs/build/schema.md

[4] [12] [31] [40] https://docs.jsonata.org/next/overview
https://docs.jsonata.org/next/overview

5 19 87 https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html
https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

6 57 https://www.w3.org/TR/trace-context/
https://www.w3.org/TR/trace-context/

7 26 62 https://www.rabbitmq.com/docs/dlx
https://www.rabbitmq.com/docs/dlx

8 70 80 101 https://docs.airbyte.com/platform/using-airbyte/core-concepts/sync-modes/incremental-append-deduped
https://docs.airbyte.com/platform/using-airbyte/core-concepts/sync-modes/incremental-append-deduped

9 92 https://martinfowler.com/articles/feature-toggles.html
https://martinfowler.com/articles/feature-toggles.html

10 https://aws.amazon.com/solutions/guidance/multi-tenant-architectures-on-aws/
https://aws.amazon.com/solutions/guidance/multi-tenant-architectures-on-aws/

11 https://help.boomi.com/docs/atomsphere/integration/deployment/c-atm-deployment_4e723d20-3e2b-41b7-8d57-010dccb940b8/
https://help.boomi.com/docs/atomsphere/integration/deployment/c-atm-deployment_4e723d20-3e2b-41b7-8d57-010dccb940b8/

13 90 https://docs.workato.com/connectors/recipeops.html
https://docs.workato.com/connectors/recipeops.html

15 58 94 https://opentelemetry.io/docs/concepts/context-propagation/
https://opentelemetry.io/docs/concepts/context-propagation/

16 https://d1.awsstatic.com/whitepapers/saas-tenant-isolation-strategies.pdf
https://d1.awsstatic.com/whitepapers/saas-tenant-isolation-strategies.pdf

17 76 https://help.boomi.com/docs/Atomsphere/Integration/Integration%20management/Setting_environment_extensions
https://help.boomi.com/docs/Atomsphere/Integration/Integration%20management/Setting_environment_extensions

18 45 88 https://datatracker.ietf.org/doc/html/rfc6749
https://datatracker.ietf.org/doc/html/rfc6749

20 https://docs.workato.com/en/troubleshooting/webhook-gateway-limits.html
https://docs.workato.com/en/troubleshooting/webhook-gateway-limits.html

21 https://docs.workato.com/en/connectors/limits.html
https://docs.workato.com/en/connectors/limits.html

24 https://owasp.org/Top10/2021/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/
https://owasp.org/Top10/2021/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/

25 60 https://learn.microsoft.com/en-us/azure/architecture/patterns/circuit-breaker
https://learn.microsoft.com/en-us/azure/architecture/patterns/circuit-breaker

27 https://microservices.io/patterns/data/transactional-outbox
https://microservices.io/patterns/data/transactional-outbox

28 37 100 https://mustache.github.io/mustache.5.html
https://mustache.github.io/mustache.5.html

29 33 39 https://jmespath.org/tutorial.html
https://jmespath.org/tutorial.html

30 https://docs.workato.com/recipes/best-practices-error-handling.html
https://docs.workato.com/recipes/best-practices-error-handling.html

32 https://github.com/jsonata-go/jsonata
https://github.com/jsonata-go/jsonata

34 https://github.com/jmespath/go-jmespath
https://github.com/jmespath/go-jmespath

35 https://handlebarsjs.com/guide/expressions.html
https://handlebarsjs.com/guide/expressions.html

36 https://github.com/aymerick/raymond
https://github.com/aymerick/raymond

38 https://github.com/hoisie/mustache
https://github.com/hoisie/mustache

42 54 98 https://www.mongodb.com/docs/manual/core/csfle/
https://www.mongodb.com/docs/manual/core/csfle/

43 https://docs.n8n.io/hosting/configuration/configuration-examples/encryption-key/
https://docs.n8n.io/hosting/configuration/configuration-examples/encryption-key/

44 https://developer.hashicorp.com/hcp/docs/vault-secrets/auto-rotation
https://developer.hashicorp.com/hcp/docs/vault-secrets/auto-rotation

46 91 https://www.rfc-editor.org/rfc/rfc7009
https://www.rfc-editor.org/rfc/rfc7009

47 89 97 https://www.ietf.org/rfc/rfc9700.html
https://www.ietf.org/rfc/rfc9700.html

48 https://cheatsheetseries.owasp.org/cheatsheets/OAuth2_Cheat_Sheet.html
https://cheatsheetseries.owasp.org/cheatsheets/OAuth2_Cheat_Sheet.html

49 https://docs.workato.com/developing-connectors/sdk/guides/authentication/oauth/auth-code.html
https://docs.workato.com/developing-connectors/sdk/guides/authentication/oauth/auth-code.html

50 https://docs.zapier.com/platform/build/auth
https://docs.zapier.com/platform/build/auth

51 https://datatracker.ietf.org/doc/html/rfc8705
https://datatracker.ietf.org/doc/html/rfc8705

52 https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html
https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

53 https://self-issued.info/docs/rfc6749.pdf
https://self-issued.info/docs/rfc6749.pdf

56 https://github.com/workato/custom_connector_docs
https://github.com/workato/custom_connector_docs

59 https://opentelemetry.io/docs/specs/semconv/http/
https://opentelemetry.io/docs/specs/semconv/http/

61 https://learn.microsoft.com/en-us/azure/architecture/patterns/retry
https://learn.microsoft.com/en-us/azure/architecture/patterns/retry

63 95 99 https://www.rabbitmq.com/docs/ttl
https://www.rabbitmq.com/docs/ttl

64 78 https://camel.apache.org/components/4.14.x/eips/dead-letter-channel.html
https://camel.apache.org/components/4.14.x/eips/dead-letter-channel.html

65 https://camel.apache.org/components/4.18.x/eips/idempotentConsumer-eip.html
https://camel.apache.org/components/4.18.x/eips/idempotentConsumer-eip.html

66 84 https://docs.n8n.io/hosting/scaling/queue-mode/
https://docs.n8n.io/hosting/scaling/queue-mode/

67 https://docs.confluent.io/kafka/operations-tools/partition-determination.html
https://docs.confluent.io/kafka/operations-tools/partition-determination.html

68 https://docs.workato.com/en/limits.html
https://docs.workato.com/en/limits.html

69 https://docs.airbyte.com/platform/connector-development/connector-builder-ui/incremental-sync
https://docs.airbyte.com/platform/connector-development/connector-builder-ui/incremental-sync

71 85 https://www.mongodb.com/docs/manual/tutorial/expire-data/
https://www.mongodb.com/docs/manual/tutorial/expire-data/

72 96 https://www.mongodb.com/docs/manual/core/timeseries/timeseries-best-practices/
https://www.mongodb.com/docs/manual/core/timeseries/timeseries-best-practices/

74 https://www.mulesoft.com/platform/exchange
https://www.mulesoft.com/platform/exchange

75 https://docs.mulesoft.com/api-manager/latest/about-configure-api-for-oauth
https://docs.mulesoft.com/api-manager/latest/about-configure-api-for-oauth

79 https://camel.apache.org/docs/
https://camel.apache.org/docs/

81 82 https://docs.airbyte.com/platform/connector-development/connector-builder-ui/authentication
https://docs.airbyte.com/platform/connector-development/connector-builder-ui/authentication

83 https://github.com/n8n-io/n8n-docs/blob/main/docs/hosting/scaling/queue-mode.md
https://github.com/n8n-io/n8n-docs/blob/main/docs/hosting/scaling/queue-mode.md

93 https://argo-rollouts.readthedocs.io/en/stable/features/canary/
https://argo-rollouts.readthedocs.io/en/stable/features/canary/